NLnet Foundation / NGI Zero Commons Fund Grant Application Dossier

Project Title: ‘pqc-immune-daemon‘: Formally Verified Post-Quantum Edge Security Membrane & Descriptor-Bound Runtime Loader
Grant Program: NLnet Foundation ? NGI Zero Commons Fund (Next Generation Internet)
Program URL: <https://nlnet.nl/commonsfund/>
Track: Free and Open Source Software (FOSS) Core Technology & Internet Commons
Applicant Profile: Rahshaun Chambers (Rocky) ? Independent Systems & Applied Cryptography Researcher
Applicant Contracting Structure: **Option A: Individual Developer / Natural Person** (Independent Open-Source Maintainer, Non-Corporate, Zero-Equity)
Target Repository: [‘pqc-immune-daemon‘](file:///home/quant/mycelium/pqc-immune-daemon) (Dual Licensed: Apache-2.0 / MIT)
Total Requested Funding: ?40,000 (Four milestone tranches: ?12k / ?12k / ?10k / ?6k)
Proposed Project Duration: 20 weeks (Five months)
Document ID: ‘QF-GRANT-NLNET-2026-001‘
Date of Dossier Reconciliation: October 31, 2026

---

1. Executive Summary & Abstract

Edge Linux devices, decentralized validator nodes, local AI agents, and public civic infrastructure face two converging security threats:
1. **"Harvest Now, Decrypt Later" (HNDL) Threat:** Passive adversaries intercepting and archiving encrypted network traffic today to decrypt retroactively once Cryptanalytically Relevant Quantum Computers (CRQCs) emerge.
2. **Time-of-Check to Time-of-Use (TOCTOU) Runtime Binary Races:** Malicious local processes or symlink races substituting binary executables or dynamic shared libraries on disk between the moment signature verification completes and the moment the kernel spawns the process into memory.

‘pqc-immune-daemon‘ is a lightweight, zero-cloud open-source project designed to solve both problems for edge and decentralized infrastructure.

This grant proposal seeks funding to advance the existing working Python prototype into a **formally verified, zero-dependency C11 core with a descriptor-bound runtime loader and an in-process WebAssembly policy membrane**:
- **Proposed Milestone 1:** Developing machine-checked F* formal specifications (‘pqc_state_machine.fst‘) and extracting a verified, zero-dependency C11 decision engine via KaRaMeL with a 10,000+ vector differential test harness.
- **Proposed Milestone 2:** Developing a standalone Linux loader binary (‘pqc-exec-bound‘) that binds cryptographic verification directly to sealed anonymous memory descriptors (‘memfd_create‘ + ‘F_SEAL_WRITE‘ + ‘fexecve‘), eliminating binary substitution attacks.
- **Proposed Milestone 3:** Compiling Open Policy Agent (OPA) Rego security assertions into an in-process WebAssembly module, providing sub-millisecond (<0.5ms) policy evaluation without open network sockets or external daemons.
- **Proposed Milestone 4:** Packaging automated CycloneDX 1.6 Cryptographic Bills of Materials (CBOM) and signed SLSA v1.0 Level 3 provenance for Alpine, Debian, and container distributions.

All project deliverables will be published under permissive open-source licenses

(Apache-2.0 / MIT) with zero cloud dependency ($0.00 cloud spend), operable on commodity and refurbished hardware.

---

2. Technical Baseline: Existing Prototype vs. Proposed Grant Work

To ensure strict truth in technical claims, the project explicitly distinguishes between the software that is **already implemented and operational today** and the **proposed deliverables to be developed under this grant**:

System Dimension	Current Prototype Baseline (Implemented Today)	Proposed Grant Deliverable (To Be Developed)
Supervisor Engine	Working Python 3.14 daemon (‘pqc-immune-daemon/immune_daemon.py‘)	Zero-dependency C11 binary extracted from formal proofs via KaRaMeL (M1)
State Machine Assurance	Unit-tested 3-state circuit breaker (‘ACTIVE‘, ‘QUARANTINE‘, ‘COLLAPSE‘)	Machine-checked F* 2026.09 formal specification with mathematical proof of non-bypassability (M1)
Runtime Process Execution	Standard POSIX process spawning & SIGHUP signal notification	Descriptor-bound ‘memfd_create‘ + ‘F_SEAL_WRITE‘ + ‘fexecve‘ kernel-sealed loader (‘pqc-exec-bound‘) (M2)
Policy Evaluation	External HTTP queries to local OPA sidecar (‘membrane_health.rego‘)	In-process WebAssembly policy membrane eliminating HTTP socket latency (<0.5ms) (M3)
Crypto-Agility Logic	‘fips_strict‘ vs ‘agility‘ fallback map configured in Rego	Automated, policy-driven ciphersuite rollover with verified state continuity (M3)
Supply-Chain Integrity	Prototype CBOM generation script & manual admission checks	Automated CycloneDX 1.6 CBOM, SLSA v1.0 Level 3 in-toto provenance, and independent verifier (M4)

Cryptographic Boundary & Invariant Disclosure

1. **Algorithmic Standards vs Certification:** ‘pqc-immune-daemon‘ targets algorithmic implementation standards (NIST FIPS 203 ML-KEM-768, NIST FIPS 204 ML-DSA-65). It does **not** claim formal NIST CMVP FIPS 140-3 module validation seals.
2. **Retirement of In-Tree C++ Wire Frames:** Experimental custom in-tree C++ FrodoKEM wire framing (0x02/0x03) and hand-written matrix math are formally retired and quarantined behind build flags. Production IPC utilizes standard OpenSSL 3.5 native providers.
3. **Control Plane Scope:** The daemon functions as a **supervisor control plane** and admission membrane. In-band mid-stream session survival requires worker protocol-level socket framing (BYO Worker); algorithm rollovers apply to subsequent sessions established by the supervised worker.

---

3. Comparison with Existing State of the Art

Capability	OpenSSL 3.5 / liboqs	AppArmor / SELinux	Commercial Cloud EDR	‘pqc-immune-daemon‘ (Grant Scope)
PQC Key Encapsulation	Raw cryptographic primitives	None	None	**Supervised ML-KEM-768 with agile fallback**

Post-Quantum Provenance	Primitive bindings	None	RSA / ECDSA only	**Conjunctive Ed25519 + ML-DSA-65 Signatures**
Formal State Machine Proofs	None	None	None	**Machine-checked F* 2026.09 proofs extracted to C11**
TOCTOU Binary Elimination	Path-based ‘execve‘	Path-based MAC rules	Heuristic agent inspection	**Descriptor-Bound ‘memfd_create‘ + ‘fexecve‘**
Policy Engine Architecture	Static configuration file	Kernel LSM security hooks	Cloud API telemetry stream	**In-Process OPA WebAssembly (<0.5ms latency)**
Cryptographic Inventory	Manual inspection	None	Proprietary dashboard	**Native CycloneDX 1.6 CBOM with NIST levels**
Operating Cost & Cloud Spend	$0.00	$0.00	$15?$60 / node / month	**$0.00 (Zero cloud dependencies, runs offline)**

---

4. Measurable Technical Milestones & Budget (?40,000)

The project is structured into four sequential, pay-per-milestone deliverables over a 20-week execution timeline:

Milestone 1: Formally Verified Decision Core & C11 Differential Suite
* **Duration:** 6 Weeks
* **Grant Allocation:** ?12,000
* **Public Deliverables:**
1. Complete machine-checked F* formal specification (‘pqc_state_machine.fst‘) modeling all state transitions (‘ACTIVE‘, ‘QUARANTINE‘, ‘RECOVERY‘, ‘COLLAPSED‘), mathematically proving progress, non-bypassability, and fail-closed termination.
2. KaRaMeL extraction pipeline generating standalone, zero-dependency C11 source code (‘pqc_core.c‘ / ‘pqc_core.h‘).
3. Differential fuzzing and parity verification suite running ‘10,000+‘ automated test vectors across Python, C11, and Wasm targets with zero divergence.
* **Verification & Acceptance Criteria:**
- Automated CI script [‘verify_formal_core.sh‘](file:///home/quant/mycelium/scripts/verify_formal_core.sh) passes cleanly in an isolated container.
- Formal proof verification succeeds via F* 2026.09 with zero admitted axioms.

Milestone 2: Descriptor-Bound ‘fexecve‘ Runtime Admission Loader
* **Duration:** 6 Weeks
* **Grant Allocation:** ?12,000
* **Public Deliverables:**
1. Linux runtime admission binary (‘pqc-exec-bound‘) implementing ‘memfd_create‘ anonymous buffer creation, hybrid cryptographic validation, kernel write sealing (‘fcntl(fd, F_ADD_SEALS, F_SEAL_WRITE | F_SEAL_SEAL)‘), and direct ‘fexecve‘ execution.
2. Multi-threaded race condition test harness simulating high-frequency inotify-triggered disk file swaps during execution (‘100%‘ block rate against TOCTOU substitution).
3. Detached Ed25519 and NIST FIPS 204 ML-DSA-65 signature verification binding verified buffer contents to release digests.
* **Verification & Acceptance Criteria:**
- Zero successful binary substitution exploits in ‘1,000‘ concurrent race test runs.
- Full POSIX compliance on Linux kernels ≥ 5.15 with standard glibc and musl compatibility.

Milestone 3: In-Process OPA WebAssembly Policy Membrane
* **Duration:** 5 Weeks
* **Grant Allocation:** ?10,000
* **Public Deliverables:**
1. Pure in-process WebAssembly policy runtime embedding ‘membrane_health.rego‘ without requiring an external HTTP daemon or open network port.
2. Complete policy-driven crypto-agility fallback matrix: strict fail-closed enforcement under default ‘fips_strict‘ (halting on algorithmic compromise with ‘recommended_fallback=NONE‘), paired with supervised emergency rollover to ISO/IEC 18033-2 ‘FrodoKEM-976-AES‘ under the research ‘agility‘ profile.
3. Three-state self-healing circuit breaker with configurable quarantine windows and clean recovery telemetry.
* **Verification & Acceptance Criteria:**
- Micro-benchmark proving average policy evaluation latency $< 0.50\text{ ms}$ on commodity x86_64 and aarch64 hardware.
- Comprehensive adversarial test suite passing 65+ boundary and fault-injection test cases.

Milestone 4: CycloneDX 1.6 CBOM, SLSA v1.0 Provenance & Independent Verifier
* **Duration:** 3 Weeks
* **Grant Allocation:** ?6,000
* **Public Deliverables:**
1. Standalone CycloneDX 1.6 CBOM generator mapping all cryptographic algorithms, parameter sets, OIDs, and NIST quantum security levels.
2. Signed SLSA v1.0 Level 3 build provenance attestation generator binding git commits, toolchain hashes, and release digests.
3. Standalone offline verification script ([‘verify_dossier_independent.py‘](file:///home/quant/mycelium/scripts/verify_dossier_independent.py)) enabling any third-party auditor to verify release integrity without proprietary dependencies.
4. Packaging and distribution recipes for Debian/Ubuntu (‘.deb‘), Alpine Linux (‘apk‘), and container images.
* **Verification & Acceptance Criteria:**
- Bit-for-bit reproducible build verified across two independent build environments.
- Clean audit pass against all 10 adversarial vectors (‘TV-M6C-01..10‘).

---

5. Public Good, Community Benefit & Open Standards

- **100% Free & Open Source:** All project outputs are published under OSI-approved permissive licenses (Apache-2.0 and MIT) with no proprietary extensions or commercial tiers.
- **Democratic Security Access:** Provides high-assurance, post-quantum runtime security to resource-constrained public institutions, hospitals, municipal networks, non-profit organizations, and human-rights defenders who cannot afford proprietary cloud EDR subscriptions.
- **Zero Cloud & Telemetry Overhead:** Requires zero paid cloud subscriptions ($0.00 cloud spend); operates completely offline with zero telemetry exfiltration.
- **Open Standards Alignment:** Aligns with NIST FIPS 203/204, CycloneDX 1.6 CBOM, SLSA v1.0, and POSIX.1-2008 standards.

---

6. Operational Governance & Financial Discipline

This grant proposal adheres strictly to the **QuantumFlex Sovereign Operating Constitution**:

1. **Applicant Legal Structure (Option A):** Applied as an independent individual FOSS researcher (Natural Person). No corporate entity, no venture capital, no sales obligations, and no shareholder dilution.
2. **Operator First & Mutual-Service Covenant (‘QF-OPS-01‘):** Workload is strictly bounded to sustainable engineering sessions ($\le 20\text{ hours/week}$), preserving personal health, family life, and academic commitments.
3. **The Golden Financial Invariant (‘QF-CAPITAL-01‘):** Liquid household reserves ($R_{\text{verified liquid}} \ge 6O$) are maintained at all times. In accordance with strict accounting rules, **unsettled or pending grant milestones are strictly excluded from liquid reserve calculations** until funds are disbursed and settled in cash.
4. **Tax Reserve Set-Aside:** A mandatory 30% tax reserve is immediately set aside from each settled milestone payment into a designated tax reserve buffer, with the remaining net funds routed to sovereign infrastructure reinvestment.

---

7. Verification Evidence & Pinned Manifest

The core prototype code, tests, and cryptographic verification mechanisms referenced in this dossier are currently implemented and verified in the QuantumFlex repository:

Artifact / Component	Repository Location	Verification Status
Supervisor Daemon	[‘pqc-immune-daemon/immune_daemon.py‘](file:///home/quant/mycelium/pqc-immune-daemon/immune_daemon.py)	Fully operational prototype
Rego Policy Bundle	[‘pqc-immune-daemon/membrane_health.rego‘](file:///home/quant/mycelium/pqc-immune-daemon/membrane_health.rego)	100% test coverage
Supply Chain & Hybrid Attestation	[‘src/admission_receipt.py‘](file:///home/quant/mycelium/src/admission_receipt.py)	550 passed tests
Economic & Milestone Gates	[‘src/bounty_assurance.py‘](file:///home/quant/mycelium/src/bounty_assurance.py)	Verified (‘M6-01..M6-07‘)
Independent Verifier	[‘scripts/verify_dossier_independent.py‘](file:///home/quant/mycelium/scripts/verify_dossier_independent.py)	Verified offline
Current Git Commit	‘56bac15‘ (‘main‘)	Clean working tree

Submitted for Operator Attestation & Public-Good Dispatch.
Architect: Rahshaun Chambers (Rocky)
QuantumFlex Autonomous Systems & Applied Cryptography